

Evidence Semantics and Scanner Orchestration

Abstract

Security tooling becomes unreliable when it treats four different questions as though they were one:

- 1 Did the assessment process execute?
- 2 Was the required source available?
- 3 What value did the source return?
- 4 What conclusion may safely be drawn from that value?

The Salesforce Security Observatory is designed around the principle that these questions must remain independent. A completed process does not prove that every source was available. An empty result does not prove that the relevant population does not exist unless the source was successfully assessed. A non-zero result does not by itself establish severity, ownership or policy breach. A control mapping does not create a compliance decision.

This paper explains the evidence semantics and scanner orchestration model used by the Observatory. It describes a Salesforce-native, read-only assessment architecture in which scanner families run through a bounded asynchronous plan, retain sanitised evidence inside the subscriber organisation, distinguish successful zero results from unavailable or incomplete evidence, and expose limitations as part of the result rather than hiding them behind a score.

The intended audience is Salesforce architects, security engineers, platform owners, auditors and technical leaders who need to understand not only what a security dashboard reports, but whether the report is entitled to make that claim.

1. The problem: security evidence is not a single value

A conventional dashboard often reduces a complex assessment to a count, badge or score. That compression is useful only when the path from source to interpretation remains trustworthy.

Consider a displayed value of zero. It can represent several materially different conditions:

- the source was queried successfully and returned no matching records;
- the source object or feature does not exist in the organisation;
- the assessing user could not see the source;
- a dependent credential was not configured;
- the query failed;
- only part of a composite source set was assessed;
- the scanner did not run;
- the evidence was not retained at the selected detail level.

Only the first condition supports a genuine **zero observed** statement. The remaining conditions describe missing, unavailable, incomplete or unassessed evidence.

The central design principle is therefore:

Execution outcome, source availability, metric value and permitted interpretation are independent dimensions. A security observation is valid only when the relationship between those dimensions is explicit.

This is more than wording discipline. It is an integrity control. If unavailable evidence is converted into zero, the system substitutes absence of evidence for evidence of absence. If incomplete evidence is presented as complete, the system hides its own visibility boundary. If a framework mapping is presented as compliance, the system converts supporting evidence into a conclusion it was never authorised to make.

2. The four-dimensional evidence model

2.1 Dimensions

Dimension	Core question	Typical values
Execution outcome	Did the scanner or orchestration step run to a known terminal state?	Completed, completed with warnings, failed, not reached, not selected
Source availability	Was the required evidence source accessible and sufficiently complete?	Available, partially available, unavailable, unsupported, not configured, not assessed
Metric value	What did the successfully assessed source return?	Non-zero, zero, categorical result, date, bounded detail, no applicable value
Permitted interpretation	What statement is justified by the other three dimensions?	Evidence observed, zero observed, incomplete, unavailable, needs review, not assessed

The dimensions are related, but none can replace another.

- A scanner can complete while a source remains unavailable.
- A source can be available while returning zero matching records.
- A metric can be non-zero without establishing whether the result is expected or unacceptable.
- A process can fail closed without producing a false-clean result, yet still be operationally inadequate if it provides no safe cause or next action.

2.2 Evidence-state matrix

Execution outcome	Source availability	Metric result	Permitted interpretation
Completed	Available and complete	One or more matching records	Evidence observed
Completed	Available and complete	Zero matching records	Zero observed
Completed	Some independent sources available; others unavailable	Any partial result	Partial or incomplete evidence
Completed	Required source unavailable	No reliable value	Unavailable
Completed with warnings	A scanner family failed but later work continued	No reliable family result	Scanner issue
Failed	Orchestration did not reach a valid completion boundary	Incomplete overall result	Assessment failed
Not selected or not retained	No assessment result exists for the requested question	No value	Not assessed
Unsupported	The organisation, edition, feature or API surface is outside the validated contract	No value	Unsupported

The status is not determined by the number alone. It is derived from the execution and source context in which the number was produced.

2.3 Genuine zero versus unavailable

A genuine zero requires all of the following:

- the intended scanner family ran;
- the required source was accessible;
- the query or API operation completed successfully;

- the source set was complete enough for the stated question;
- the result contained no matching records;
- the retained evidence can distinguish this condition from missing output.

When any of these conditions is not satisfied, zero is not a safe substitute.

Preferred public wording:

No matching exposure evidence was observed within the assessed sources.

Avoid:

No exposure exists.

The first statement defines the source and assessment boundary. The second asserts an absolute condition that the scanner normally cannot prove.

3. The public scanner contract

The Observatory treats each scanner family as an evidence-producing component with an explicit success, zero, partial and failure contract.

Stage or condition	Required behaviour	Prohibited substitution
Source acquisition succeeds	Process the returned records within the defined scope and limits.	Do not claim sources were assessed that were not queried.
Successful empty result	Record zero observed with the assessed source and limitation.	Do not generalise a source-specific zero into an organisation-wide guarantee.
Source acquisition fails	Record unavailable or a scanner issue with a safe cause and next action.	Do not write a synthetic zero.
Only part of a composite source succeeds	Preserve usable evidence and mark the result incomplete. Identify the unavailable evidence category safely.	Do not calculate a complete total from a partial source set.
Individual scanner exception	Isolate the family where safe, retain a non-green family state and continue later planned work.	Do not erase the failure or relabel it as an empty result.
Orchestration transaction failure	Fail the assessment boundary, retain the safest available status and stop unstarted segments.	Do not present a partially executed assessment as complete.
Known safe failure category	Persist an approved, bounded reason code and safe next action.	Do not persist raw exception messages, stack traces or queries.
Unknown failure category	Use a generic fail-closed reason.	Do not invent precision that cannot be derived safely.
Raw diagnostic information	Keep transient and sanitised for controlled engineering diagnosis.	Do not expose it through the dashboard, exports or retained evidence.
Historical scan review	Interpret the selected scan from its retained evidence and the rules recorded for that scan.	Do not substitute current live state or current mapping configuration.

This contract is intended to remain consistent across dashboard cards, drill-downs, comparison, exports and supporting framework views.

4. Evidence confidence is a ladder, not a binary claim

Technical documentation often uses words such as *implemented*, *validated*, *supported* and *proven* interchangeably. They are not equivalent.

The Observatory uses a deliberately graduated vocabulary.

Confidence level	Meaning
Source-established	The behaviour is visible in the reviewed implementation source.

Confidence level	Meaning
Test-observed	An automated test exercised the behaviour under a controlled fixture.
Runtime-observed	The behaviour occurred in a reviewed organisation execution.
Release-validated	The behaviour passed the defined release gates on the exact release candidate.
Supported	The behaviour is part of the approved product contract for a stated environment and prerequisites.
Expected	Architecture or platform evidence suggests the behaviour should work, but the required validation is incomplete.
Not assessed	No reliable conclusion is available.

A single successful execution is runtime evidence for that execution. It is not universal proof for every organisation of the same edition.

For the current orchestration model, the defensible statement is:

Observed completing in the reviewed Developer Edition execution; broader support is governed by the compatibility matrix current at the time of reading.

The compatibility matrix evolves as representative release validation is completed and must not be read as a finished all-edition support statement. This wording preserves the evidence without turning one sample into an edition-wide guarantee.

5. Compatibility vocabulary

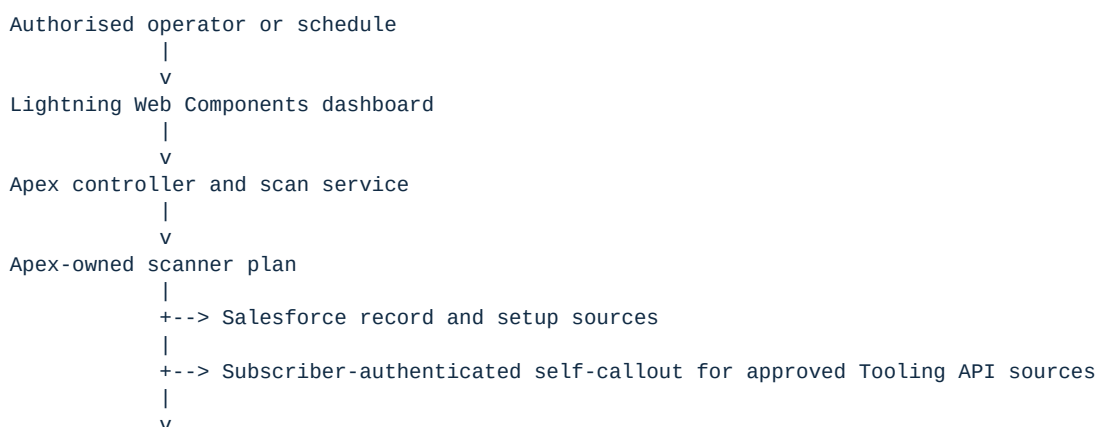
Public support statements use the following terms.

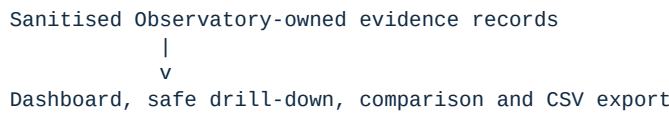
Term	Meaning
Validated	Tested successfully on the exact stated release candidate and representative environment.
Supported with prerequisite	Supported when the stated Salesforce feature, permission or subscriber-controlled credential setup is present.
Expected but not validated	The design appears compatible, but representative runtime proof is incomplete.
Unsupported	Outside the approved product boundary or known not to meet a required dependency.
Not assessed	No support conclusion has been reached.

The compatibility matrix must identify the relevant organisation type, required platform features, self-callout prerequisites, evidence limitations and validation status. Installation capability alone is not treated as runtime support.

6. Salesforce-native architecture

The Observatory runs inside the subscriber Salesforce organisation.





Text alternative: An authorised user or schedule starts the scan through the Lightning dashboard. Apex owns the scanner plan. Scanner families read approved Salesforce sources, with some metadata sources requiring a subscriber-authenticated self-callout. The resulting sanitised evidence is stored in Observatory-owned Salesforce records and presented through the dashboard, comparison and export surfaces.

6.1 Architectural properties

- **Salesforce-native execution:** the dashboard, orchestration, scanners and evidence storage run on the Salesforce platform.
- **Read-only assessment of security configuration:** scanners inspect Salesforce data, setup and metadata sources but do not remediate them.
- **Observatory-owned evidence writes:** the product writes only the records required to retain its own scan status, metrics, findings, details, assets and comparison evidence.
- **No external evidence destination:** the design does not require scan evidence to be sent to an externally hosted service.
- **Subscriber-controlled authentication:** Tooling API access uses a credential and principal configured and authorised in the subscriber organisation.
- **Sanitised evidence boundary:** retained and exported evidence excludes bearer credentials and other attacker-useful raw values.

6.2 User access and database modes

User-facing data access is designed around explicit sharing, CRUD and field-level security boundaries. Database access modes are selected deliberately rather than left implicit.

Most user-facing source and evidence operations should enforce the current user's authorised visibility. Narrow system-mode operations are reserved for explicit lifecycle responsibilities where ordinary personas must not receive the equivalent delete or field permissions.

This distinction matters because a product can be read-only with respect to Salesforce security configuration while still writing and maintaining its own evidence records.

7. Why the scanner plan is segmented

Salesforce is a multitenant platform with per-transaction governor limits. A security assessment that combines data queries, metadata reads, callouts, evidence persistence and comparison state should not assume that every operation belongs in one transaction.

The Observatory therefore uses a bounded Queueable plan. The plan is ordered by Apex, not duplicated in the browser. Scanner families are divided into sequential transaction segments according to their callout and non-callout characteristics.

The current reviewed plan resolves into five Queueable transactions:

- 1 an initial non-callout segment;
- 2 a callout-led segment followed by compatible non-callout families;
- 3 a dedicated metadata-callout segment;
- 4 a second dedicated metadata-callout segment;
- 5 a final callout-led segment followed by the remaining compatible non-callout families.

This description reflects the currently implemented segmentation and the reviewed Developer Edition execution. Any change to scanner order, callout classification or batching limits requires the description to be re-verified before

publication.

The public significance is not the internal scanner names. It is the transaction contract:

- callout boundaries are explicit;
- compatible non-callout work may share the same transaction;
- each segment executes in a fresh asynchronous context;
- a segment may enqueue one next segment;
- later segments receive the retained orchestration context they need;
- finalisation occurs only after the plan reaches its terminal boundary.

The design schedules within Salesforce's asynchronous Apex constraints. It does not claim to bypass platform limits.

7.1 Why not one transaction?

A single transaction would create unnecessary coupling between unrelated evidence sources and increase the risk that one limit or callout boundary prevents the remainder of the assessment from running.

7.2 Why not one job per scanner?

A separate transaction for every scanner family would create avoidable asynchronous overhead and a deeper chain. The bounded segmentation model groups compatible work while isolating callout boundaries.

7.3 Why not let the browser choose the scanner list?

Client-owned scanner selection risks divergence between manual scans, scheduled scans and later API entry points. Keeping the canonical plan in Apex ensures that supported entry points invoke the same ordered assessment contract.

Evidence detail level controls how much safe evidence is retained, displayed, compared and exported. It does not silently redefine which scanner families constitute the normal complete plan.

8. Failure isolation and finalisation

The architecture distinguishes two failure classes.

8.1 Individual scanner-family failure

An individual scanner failure can be isolated so that later families continue where the surrounding transaction remains healthy.

The expected result is:

- the affected family is non-green;
- the scan records that warnings occurred;
- later planned families continue;
- finalisation reports completion with warnings rather than an unqualified success;
- supporting framework evidence that depends on the affected family is degraded.

Continuation is not the same as success. It preserves useful independent evidence while keeping the failed family visible.

8.2 Orchestration transaction failure

A failure outside the scanner-isolation boundary affects the transaction itself. In that case:

- the scan moves to a failed state through the safest available lifecycle path;
- unstarted later segments do not run;
- retained status evidence is written on a best-effort, fail-closed basis;

- the result must not be presented as a complete assessment.

8.3 Finalisation boundary

Finalisation is responsible for more than changing a status label. It is the point at which the system can safely:

- calculate the terminal scan state;
- record the number of scanner-family failures;
- persist scanner-family status rows;
- persist supporting control outcomes where applicable;
- apply the configured retention policy;
- expose the completed assessment to comparison and export.

If required final evidence cannot be retained, the product must not quietly claim a fully complete scan.

9. Source availability is part of the evidence

A scanner family can depend on one source or several independent sources. The availability of those sources must be treated as evidence in its own right.

For each required source, the scanner should be able to establish:

- whether the object, API or feature is supported;
- whether the necessary fields can be discovered;
- whether the source is visible to the assessing context;
- whether the query or callout completed;
- whether the returned result was complete within the documented bounds;
- whether dependent enrichment was available;
- whether a zero result was genuinely observed.

For composite scanners, a single family-wide Boolean is often insufficient. If one source succeeds and another fails, the family result is partial, not complete and not necessarily empty.

The safe model is:

```
Source A: available, 3 records
Source B: unavailable
Overall family: partial evidence
Permitted statement: evidence was observed from Source A; Source B was not assessed
```

It is not:

```
Overall family: 3 records, complete
```

and it is not:

```
Source B: 0 records
```

This source-completeness dimension is essential for interpreting both zero and non-zero counts.

10. Safe reasons and diagnostic separation

Security products need enough diagnostic information to guide an administrator without retaining raw material that creates new risk.

The Observatory separates two channels.

10.1 Retained operational evidence

Retained evidence uses a closed set of approved reason categories such as:

- source query unavailable;
- source visibility limited;
- dependency unavailable;
- unsupported organisation feature;
- coverage limited;
- family execution failed;
- unknown state.

The category is intentionally bounded. It can be displayed, compared and exported safely with an administrator action.

10.2 Transient engineering diagnostics

Short-lived platform diagnostics may contain a sanitised exception type and bounded message for engineering diagnosis. They are not the authoritative evidence contract and are not copied into dashboard records or public exports.

10.3 Normalisation invariants

A safe reason taxonomy requires automated invariants:

- every approved code must survive its own normaliser unchanged;
- every unapproved code must be rejected;
- diagnostic-shaped or sensitive strings must remain rejected;
- unsafe substring rules must not silently invalidate an approved code;
- unknown conditions must fall back to a generic fail-closed category.

The aim is not maximum diagnostic detail. It is the safest useful explanation that can be derived deterministically.

11. Sanitisation and data minimisation

The Observatory is intended to reduce security-review effort without becoming a second repository of secrets.

11.1 Data that may be retained

Subject to the selected evidence level and user permissions, retained evidence can include:

- bounded counts and dates;
- safe names and categories;
- status and source identifiers that are necessary for review;
- sanitised findings and recommendations;
- scanner-family state and approved reason category;
- safe asset relationships;
- evidence limitations;
- comparison state derived from retained scans.

11.2 Data that is excluded

The evidence boundary excludes:

- access tokens;

- refresh tokens;
- session identifiers;
- passwords and client secrets;
- private keys;
- certificate bodies;
- raw authorisation headers;
- raw platform responses;
- raw stack traces and queries;
- raw IP values;
- any value retained merely because it was available rather than because it was necessary.

11.3 Export safety

CSV output is treated as an independent security boundary. Exported cells require consistent quoting and formula-injection protection. A value safe to render as text in Salesforce is not automatically safe when opened by spreadsheet software.

Export must also preserve evidence limitations. A filtered or capped export must not imply that it represents the complete organisation.

12. The subscriber-controlled self-callout

Some Salesforce metadata sources are accessible through the Tooling API rather than ordinary SOQL. Apex code invoked from Lightning does not automatically receive an API-enabled user session for arbitrary Salesforce API calls. The Observatory therefore uses a subscriber-controlled named credential pattern for the approved self-callout path.

At a high level:

```
Apex callout
  -> Named Credential
    -> External Credential
      -> subscriber-authorised principal
        -> subscriber organisation Tooling API
```

Salesforce Named Credentials separate the endpoint definition from the authentication protocol and principal. External Credential principals are mapped to authorised users through Salesforce permissions. Sensitive authentication tokens are stored by Salesforce as user external credentials rather than exposed to Apex or ordinary API queries.

The public security properties are:

- no hard-coded endpoint credentials in Apex;
- no packaged access or refresh tokens;
- subscriber-owned authorisation;
- explicit principal access;
- a revocable operational kill switch;
- Tooling-backed evidence degrades visibly when the prerequisite is missing or unavailable;
- ordinary SOQL-backed scanner families can remain independent of the self-callout.

A self-callout is still an authenticated API path and must be reviewed carefully. The use of a named credential does not by itself make a callout read-only. Read-only behaviour depends on the implementation and the permissions granted to the principal.

13. Historical evidence integrity

A retained scan is a statement about what was assessed at a particular time, under a particular evidence level, source visibility and mapping revision.

Historical interpretation must therefore use the evidence retained with that scan.

The Observatory must not:

- requery current live sources to fill gaps in an older scan;
- use current configuration to reinterpret an older result;
- treat evidence omitted at a lower detail level as resolved;
- compare scans with incompatible evidence levels as though they were like-for-like;
- convert a legacy unknown state into a current zero.

13.1 Comparison contract

A comparison is reliable only when the evidence bases are compatible.

Like-for-like comparison can support statements such as:

- new evidence observed;
- previously observed evidence no longer present within the same assessed scope;
- repeated evidence;
- changed severity or count;
- changed asset or entitlement state.

When evidence levels, source availability or mapping context differ materially, the correct result is **comparison unavailable** or **needs review**, not improved or resolved.

13.2 Retention and evidence depth

Retention is bounded because Salesforce data storage is finite. Evidence level changes the depth of retained detail, not the meaning of a scanner success or failure.

A lower evidence level may retain counts without item-level identities. The interface must reflect that limitation by disabling drill-downs that do not have safe retained detail.

14. Supporting framework evidence is not compliance

The Observatory can associate retained evidence with Security Benchmark for Salesforce control identifiers. This supports traceability between a control and the evidence that may help review it.

The mapping does not establish:

- that the control is satisfied;
- that the organisation is compliant;
- that no compensating control exists;
- that policy and ownership requirements have been met;
- that the configuration is secure in its business context.

The public distinction is:

Question	Observatory answer
Did the scanner family return usable evidence?	Scanner-family evidence state
What evidence applies to a finding?	Finding/detail evidence state

Question	Observatory answer
How does the evidence relate to an SBS control?	Coverage or supporting-evidence state
Is the organisation compliant with the control?	Requires formal assessment outside the Observatory

Terms such as **Automated**, **Partial Evidence**, **Manual Required**, **Not Covered** and **Extended Check** describe evidence coverage, not compliance outcomes.

15. Public wording discipline

The wording used by a security product is part of its control design.

Avoid	Use
No exposure exists.	No matching exposure evidence was observed within the assessed sources.
The organisation is secure.	The selected checks returned the evidence described in this assessment.
The scanner passed.	The scanner family returned usable evidence.
Clean.	No matching risk evidence was surfaced within the stated scope.
No users are affected.	No matching users were observed in the successfully assessed source.
The token is active.	An OAuth authorisation record was retained, or point-in-time activity evidence was observed, as stated.
The control is compliant.	The retained evidence supports review of the mapped control identifier.
All Salesforce editions are supported.	See the compatibility matrix for validated environments and prerequisites.
Proven in Developer Edition.	Observed completing in the reviewed Developer Edition execution.
Platform limits are bypassed.	The scanner plan is segmented to execute within Salesforce transaction boundaries.

Wording should state the assessed source, time, limitation and evidence basis where these materially affect interpretation.

16. Validation philosophy

The release process should verify more than code coverage.

A defensible validation set includes:

- source review of the canonical scanner plan;
- automated tests for non-zero, zero, unavailable, partial and failure paths;
- table-driven reason-code normalisation tests;
- tests that raw diagnostic-shaped values cannot persist;
- scanner-family persistence tests;
- downstream dashboard and export tests;
- controlled runtime execution in a representative organisation;
- compatibility and prerequisite checks;
- package installation and upgrade evidence where distribution is claimed;
- non-System-Administrator persona testing;
- public-copy sanitisation and overclaim review.

Coverage percentage is useful, but it does not prove that the evidence semantics are correct. A high-coverage test suite can still encode the wrong expected behaviour. Tests must assert the product contract, particularly the

distinction between zero, unavailable and partial evidence.

17. Known limitations

The Observatory is deliberately bounded.

- It is advisory and read-only with respect to Salesforce security configuration.
- It does not remediate findings.
- It does not prove that a retained OAuth authorisation is a currently usable token.
- It does not replay credentials or test access by attempting to use them.
- It does not ingest platform telemetry, provide real-time security monitoring, or replace formal audit activity.
- Some metadata evidence depends on a subscriber-authorised self-callout.
- Evidence visibility depends on the approved user and principal permissions.
- A successful execution in one organisation does not establish universal edition support.
- Retention and evidence detail are intentionally bounded.
- Framework mapping provides supporting evidence, not certification.
- Unsupported or unavailable sources remain non-green and require review.

These limitations are part of the product contract. They are not footnotes to be hidden after a score.

18. Design rationale summary

Decision	Rationale
Keep scanner-plan ownership in Apex	Prevents client, schedule and API entry points from drifting apart.
Segment the plan into bounded Queueable transactions	Separates callout boundaries and resets per-transaction limits without creating one job per scanner.
Continue after isolated scanner-family failure	Preserves independent evidence while keeping the failed family non-green.
Fail the scan on orchestration failure	Prevents a partially executed plan from appearing complete.
Treat source availability as evidence	Distinguishes genuine zero from missing visibility.
Persist only approved reason categories	Provides operational value without storing raw diagnostic material.
Keep detailed diagnostics transient	Reduces attacker-useful retained information.
Use subscriber-controlled Named and External Credentials	Avoids hard-coded secrets and preserves subscriber ownership of authentication.
Retain evidence inside Salesforce	Keeps evidence within the subscriber's platform and access model.
Compare only compatible retained evidence	Prevents omitted or incompatible evidence from appearing resolved or improved.
Keep SBS mapping separate from compliance	Prevents supporting evidence from becoming an unsupported assurance claim.

19. Conclusion

A security dashboard is trustworthy only when it can explain the path from source to statement.

The Salesforce Security Observatory's core architectural proposition is therefore not that it can produce more counts. It is that every count, zero, warning and unavailable state must retain enough context to answer:

- what ran;
- what source was assessed;

- what the source returned;
- what could not be assessed;
- what the result permits the operator to conclude;
- what limitation or next action remains.

This approach treats evidence semantics as part of security engineering rather than as presentation copy. The asynchronous scanner plan, source-availability model, safe reason taxonomy, sanitised evidence boundary and historical comparison rules all serve the same objective: prevent the system from claiming more than its evidence supports.

The most important distinction is simple:

Nothing found and nothing assessed are not the same result.

References

- 1 Salesforce Developers, **Secure Apex Classes**:
<https://developer.salesforce.com/docs/platform/lwc/guide/apex-security>
- 2 Salesforce Developers, **Call APIs from Apex**:
<https://developer.salesforce.com/docs/platform/lwc/guide/data-api-calls-apex.html>
- 3 Salesforce Developers, **Get Started with Named Credentials**:
<https://developer.salesforce.com/docs/platform/named-credentials/guide/get-started.html>
- 4 Salesforce Developers, **Named Credentials Glossary**: <https://developer.salesforce.com/docs/platform/named-credentials/references/named-credentials-reference/nc-glossary.html>
- 5 Salesforce Developers, **Package Named Credentials**:
<https://developer.salesforce.com/docs/platform/named-credentials/guide/nc-package-credentials.html>
- 6 Salesforce Developers, **Populate External Credential Principals**:
<https://developer.salesforce.com/docs/platform/named-credentials/guide/nc-populate-external-credentials.html>
- 7 Salesforce Developers, **Exploring a Combined Async Apex Framework**:
<https://developer.salesforce.com/blogs/2023/02/exploring-a-combined-async-apex-framework>
- 8 Security Benchmark for Salesforce documentation: <https://docs.securitybenchmark.org/>